

Nikto

Source: <https://cirt.net>

Nikto is an Open Source (GPL) web server vulnerability scanner that can perform wide-ranging tests against web servers of over 6700 potentially dangerous files/CGIs and can check for any older versions of over 1250 servers, and version specific problems on over 270 servers. It also checks for server configuration items, HTTP server options, captures, and prints any cookies received and tries to identify any newly installed web servers and software.

Nikto Parameters

Parameter	Description
-ask	Ask about submitting updates: yes (ask about each-- the default), no (don't ask, just send), auto (don't ask, just send)
-Cgidirs	Scan CGI directories by using special words "none" or "all"
-config	Use an alternative config file instead of the nikto.conf file
-dbcheck	Verify the scan databases for syntax errors
-Display	Use to control the output of Nikto
-evasion	Input the LibWhisker encoding/evasion technique to use
-findonly	Identify the HTTP(S) ports without performing security scan
-host	IP address, hostname or text file of hosts
-id	Give ID and password for host Basic host authentication. The format is "id:password"
-IgnoreCode	Ignore HTTP codes as negative responses
-list-plugins	Display all plugins that Nikto can run against targets
-maxtime	Retrieves maximum execution time per host, in seconds
-mutate	Input mutation technique. This will cause Nikto to combine tests or attempt to guess values
-mutate-options	Input extra information for mutates, e.g. a dictionary file
-nolookup	Avoid performing name lookups on IP addresses
-nocache	Disable response cache
-nointeractive	Disable interactive features
-noss1	Do not use SSL to connect to the server
-no404	Disable 404 (file not found) checking
-output	Specify the file to write output
-Plugins	Give plugins to run on the specified targets
-port	Specify TCP port(s) to target
-Pause	Seconds (integer or floating-point) to delay between each test
-root	Prepend the value specified to the beginning of every request
-ssl	Only check SSL on the ports specified
-Save	Save request/response of findings to this directory

Parameter	Description
-timeout	Seconds to wait before timing out a request. The default timeout is 10 seconds
-Tuning	Control the test that Nikto will use against a target
-Userdbs	Load user-defined databases instead of standard databases
-until	Execute until the specified time or duration, then pause
-update	Update the plugins and databases directly from cirt.net
-useproxy	Use the HTTP proxy defined in the configuration file
-Version	Display the Nikto software, plugin and database versions
-vhost	Specify the Host header to be sent to the target

Parameter	Description
-evasion 3	Premature URL ending
-evasion 4	Prepend long random string
-evasion 5	Fake parameter
-evasion 6	TAB as request spacer
-evasion 7	Change the case of the URL
-evasion 8	Use Windows directory separator (\)
-evasion A	Use a carriage return (0x0d) as a request spacer
-evasion B	Use binary value 0x0b as a request spacer

Types of Display Options

Parameter	Description
-Display 1	Shows redirects, that displays all requests which receive a "redirect" response from the server
-Display 2	Displays cookies received from a remote host
-Display 3	Retrieves all 200/OK responses
-Display 4	Retrieves URLs which require authentication
-Display D	Debug output. Show debug output, which shows the verbose output and extra information such as variable content
-Display E	Display details of all HTTP errors
-Display P	Displays progress to STDOUT
-Display V	Gives verbose output

Types of Evasion Options

Parameter	Description
-evasion 1	Random URI encoding (non-UTF8)
-evasion 2	Directory self-reference (./.)